

1. Nmap Port and Service Scan

Step 1 — Find the target IP

On the Windows 10 VM:

- ipconfig

Example:

- IPv4 Address : 10.205.208.100

Use your actual Windows 10 VM IP in the commands below.

Step 2 — Basic Nmap scan

From Kali Linux:

- nmap 10.205.208.100

Step 3 — Service/version detection

- nmap -sV 10.205.208.100

Step 4 — More detailed scan

- nmap -sC -sV 10.205.208.100

Save the result:

- nmap -sC -sV 10.205.208.100 -oN nmap_results.txt

2. Vulnerability Scan Using OpenVAS/Nessus

OpenVAS / Greenbone

If OpenVAS is already installed on your Kali/Linux VM, start the services according to your installation and access the Greenbone web interface.

Create a new target:

- Target: Windows 10 VM
- IP: 10.205.208.100

Then create a scan task using the appropriate full vulnerability scan profile.

Start the scan and wait for completion.

3. Research One High/Critical Vulnerability

Choose one vulnerability from your actual OpenVAS/Nessus report.

A good choice is a vulnerability with:

- Critical/High severity
- High CVSS score
- Remote code execution
- No/low authentication requirements
- Network-accessible attack surface

Example: EternalBlue / MS17-010

If your scan actually reports MS17-010, you can use this example.

CVE: CVE-2017-0144

Affected technology: Microsoft SMBv1

Severity: Critical

Attack surface: TCP/445

Short Impact Summary

CVE-2017-0144 is a vulnerability in Microsoft's SMBv1 implementation. A specially crafted request can allow an attacker to execute code remotely on a vulnerable system.

Because SMB commonly operates through TCP port 445, an exposed vulnerable Windows system can potentially be attacked over the network.

Successful exploitation could allow an attacker to gain control over the affected system, depending on the system's configuration and privileges. This could potentially expose files, credentials, applications, and other information stored or accessible by the system.

Potentially affected assets

An attacker who successfully compromises the system could potentially gain access to:

- Local files
- Shared folders
- System configuration
- Running applications
- Credentials/tokens accessible to the compromised account
- Other systems reachable from the compromised machine

4. Prioritized Recommendations

Priority 1 — Critical/RCE vulnerabilities

Finding: Critical vulnerability with remote code execution capability.

Recommendation:

- Install the latest security patches from Microsoft.
- Remove/disable vulnerable legacy components where possible.
- Re-run the vulnerability scan after patching.
- Restrict network access to the affected service until remediation is complete.

Priority: Critical

Priority 2 — Exposed SMB

Finding: TCP/445 SMB exposed unnecessarily.

Recommendation:

- If SMB is not required:
 - Disable the unnecessary SMB service.

If SMB is required:

- Apply all security updates.
- Disable SMBv1 where it is not required.
- Restrict SMB access using Windows Firewall.
- Allow SMB only from trusted network segments.

Priority: High

Priority 3 — RDP Exposure

Finding: TCP/3389 RDP is accessible.

Recommendation:

- If RDP is unnecessary:
 - Disable Remote Desktop.

If it is required:

- Restrict RDP to trusted IP addresses.
- Use Network Level Authentication.
- Enforce strong passwords.
- Apply Windows security updates.
- Avoid exposing RDP directly to the Internet.

Priority: High

Priority 4 — Unnecessary Services

Finding: Services are running that are not required.

Recommendation:

- Identify unnecessary services and disable them.

For example:

- Get-Service

Only disable a service after confirming that Windows or required applications do not depend on it.

Priority: Medium

Priority 5 — Information Disclosure

Finding: Service/version information is exposed.

Recommendation:

- Keep applications updated.
- Remove unnecessary services.
- Restrict access to management interfaces.
- Avoid exposing unnecessary version information where practical.

Priority: Low/Medium

5. Present the report to your peer

Slide/Section 1 — Objective

The objective of this assessment was to identify exposed network services and potential vulnerabilities on the provided virtual machine and provide prioritized remediation recommendations.

Slide 2 — Methodology

Nmap



Port/service discovery



Nessus



Vulnerability identification



CVE research



Risk prioritization



Remediation

Slide 3 — Nmap results

Show your actual:

- Open ports
- Services
- Versions

Slide 4 — Vulnerability results

Show:

- Critical: X
- High: X
- Medium: X
- Low: X

Slide 5 — Most important finding

Explain your selected CVE:

- CVE:
- Affected software:
- CVSS:
- Attack vector:
- Potential impact:
- Recommended fix:

Slide 6 — Recommendations

Show your priority table.

Slide 7 — Conclusion

The assessment identified several security findings on the tested virtual machine. The highest-priority issues should be addressed first through vendor patching, service restriction, or configuration changes. After remediation, a follow-up vulnerability scan should be performed to verify that the findings have been resolved.

Two questions your peer might ask

Q1. "Why is this vulnerability your highest priority?"

Answer:

It was prioritized because it has a high severity/CVSS rating and the affected service is exposed to the network. The vulnerability documentation indicates that successful exploitation could have significant security consequences. Therefore, patching or restricting access to the affected service should happen before lower-severity findings.

Q2. "What happens if we can't patch it immediately?"

Answer:

Until the permanent fix can be applied, I would recommend reducing exposure by restricting access to the affected service using firewall rules or network segmentation. The temporary mitigation should remain in place until the vendor patch is installed and a follow-up scan confirms remediation.